

Plantilla de Reporte Ejecutivo (PowerPoint) para resultados de la encuesta GQM + PRAGMATIC APT

Objetivo: presentar a alta dirección, consejos y comités de riesgo una visión clara, basada en evidencia, de la madurez frente a APT, la alineación con objetivos nacionales y el retorno de la inversión.

Cada diapositiva incluye un título, un breve mensaje clave y sugerencias de visualización (gráficos, tablas, iconos).

El diseño asume una plantilla corporativa con colores institucionalizados (ej. azul corporativo y gris) y uso de iconos simples.

Diapositiva 1 – Portada

- Título: Estado de Madurez frente a Amenazas Persistentes Avanzadas (APT)
- Subtítulo: Resultados de la Encuesta de Autoevaluación GQM + PRAGMATIC
- Datos: Nombre de la organización (o agregado sectorial), período de la encuesta (ej. abr-jun 2026), logo de la entidad y logo del estudio (si corresponde).
- Nota al pie: “Informe basado en metodología GQM + PRAGMATIC, alineado con NIS2, NIST CSF 2.0, ISO 27001:2022 y MITRE ATT&CK®”.

Diapositiva 2 – Contexto y objetivos

- Viñeta 1: Breve recordatorio de la amenaza APT en España (datos INCIBE 2025: 122 k incidentes, +26 % interanual).
- Viñeta 2: Objetivos nacionales vinculados a la encuesta (reducir MTTD a ≤ 4 h, MTTR a ≤ 24 h, etc. – tabla resumida de Goals G1-G7).
- Viñeta 3: Metodología: GQM para trazar objetivos-preguntas-métricas; PRAGMATIC para garantizar calidad de las métricas.
- Visual: Icono de objetivo – pregunta – métrica (flujo simple).

Diapositiva 3 – Metodología y muestra

- Viñeta 1: Población objetivo: organizaciones con actividad en España, públicas y privadas, de todos los tamaños.
- Viñeta 2: Técnica de muestreo: estratificado por sector y tamaño, con objetivo de ≥ 200 respuestas representativas.
- Viñeta 3: Número de respuestas obtenidas y tasa de respuesta.
- Viñeta 4: Escalas usadas: 0-3 de madurez, opciones simples/múltiples, y campos de comentario abierto.
- Visual: Diagrama de bloques de la encuesta (10 bloques) con número de preguntas por bloque.

Diapositiva 4 – Índice Global de Madurez (IGM)

- Mensaje clave: El IGM resume en un solo número (0-1) la capacidad de la organización para detectar, responder y prevenir APT.
- Gráfico: Medidor tipo gauge o barra horizontal que muestra el IGM promedio de la muestra (ej. 0.58) con rangos de interpretación (0-0.25 inicial, 0.26-0.50 básica, 0.51-0.75 intermedia, 0.76-1.00 avanzada).
- Comparativa: Línea de referencia del IGM medio nacional (si se dispone) y del sector concreto.
- Nota: Desglose por bloque (ver diapositiva 5).

Diapositiva 5 – Madurez por bloques (radar o barra apilada)

- Eje X: Bloques (Gobernanza, Riesgo, Vectores de entrada, Detección, Respuesta, Cultura, Inversión, Colaboración, Visión de futuro).
- Eje Y: Valor del sub-índice IGM_b (0-1).
- Tipo de gráfico: Radar (para ver fortalezas y debilidades) o barra apilada horizontal (para facilitar lectura).
- Highlight: Bloques con IGM_b < 0.4 (áreas de mejora crítica) y > 0.7 (fortalezas).
- Comentario: Breve interpretación de los resultados más relevantes (ej. “La detección es relativamente fuerte (0.62) pero la gobernanza muestra oportunidad (0.48)”).

Diapositiva 6 – Métricas operativas clave (MTTD, MTTR, MTTP, % Phishing)

- Tabla: Métrica | Valor medio muestra | Objetivo nacional (2027) | Cumplimiento (Sí/Parcial/No)
- MTTD (h) | X.X | ≤ 4 |
- MTTR (h) | X.X | ≤ 24 |
- MTTP (días) | X.X | ≤ 7 |
- % Phishing | X% | $\leq 15\%$ |
- Gráfico de tendencias (si se dispone de históricos): evolución de cada métrica a lo largo de los últimos 3 años (si la encuesta se repite).
- Icono de alerta (●/●/●) según nivel de cumplimiento.

Diapositiva 7 – Cobertura de TTPs MITRE ATT&CK

- Mensaje: La detección basada en comportamiento es esencial para anticipar APT.
- Tabla: TTP | Puntuación media (0-3) | Nivel de capacidad (Bajo/Medio/Alto) | Comentario (ej. “Se detecta manualmente en logs”).
- System Information Discovery
- Ingress Tool Transfer
- Web Protocols (C2)
- Credential Access
- Lateral Movement
- Gráfico de barras: puntuación media por TTP.
- Nota: Se indica qué porcentaje de organizaciones alcanzó nivel 3 (detección automatizada y correlacionada).

Diapositiva 8 – Plan de respuesta y simulacros

- Viñeta 1: % organizaciones con Plan de Respuesta a Incidentes formal (Alineado ISO27035).
- Viñeta 2: Frecuencia de ejercicios: table-top anual, red team/purple team, etc.
- Viñeta 3: Métricas operativas de respuesta (MTTR contención, MTTR erradicación, tiempo de comunicación al Consejo).
- Visual: Línea de tiempo de un incidente típico con marcas de detección, contención, erradicación y comunicación.
- Comentario: Breve reflexión sobre la necesidad de aumentar la frecuencia y realismo de los simulacros.

Diapositiva 9 – Cultura, formación y reporte

- Viñeta 1: % con formación obligatoria anual para todo el personal.
- Viñeta 2: Existencia de canales de reporte (botón en correo, buzón seguridad, anónimo).
- Viñeta 3: Número medio de reportes de phishing por 1000 empleados/año.
- Viñeta 4: Percepción interna de la ciberseguridad como prioridad estratégica (Alta/Media/Baja/Muy baja).
- Gráfico: Distribución de respuestas a la pregunta 32 (pie chart).
- Comentario: Correlación entre cultura de reporte y reducción de % phishing (si los datos lo permiten).

Diapositiva 10 – Inversión, ROI y prioridades

- Viñeta 1: Rango de inversión anual (% del presupuesto de TI) por sector (box-plot).
- Viñeta 2: Existencia de modelo de ROI formal (Sí/Parcial/No).
- Viñeta 3: ROI medio estimado bajo escenarios realista y optimista (ver plantilla Excel).
- Viñeta 4: Top-3 de prioridades de inversión seleccionadas por las organizaciones (agrupación de respuestas a P41).
- Visual: Gráfico de barras horizontales con las tres prioridades más votadas.
- Nota: Conexión entre mayor IGM y mayor ROI (dispersión opcional).

Diapositiva 11 – Roadmap de mejora (12-24 meses)

- Encabezado: Acciones recomendadas basadas en los resultados de la encuesta.
- Tabla de fases:

Trimestre	Área	Acción principal	Métrica de seguimiento	Responsable
Q3-2026	Gobernanza	Aprobar estrategia APT a nivel de Consejo	IGM_Gobernanza ≥ 0.55	CISO/Consejo
Q4-2026	Detección	Implementar correlación de TTPs MITRE en SIEM	IGM_Detección ≥ 0.65	SOC Lead
Q1-2027	Vulnerabilidades	Automatizar parcheo ≤ 7 días CVSS ≥ 7	MTTP ≤ 5 días	Equipo de Parcheo
Q2-2027	Cultura	Lanzar campaña de simulacros de phishing trimestrales	% Phishing $\downarrow 20\%$	Formación
Q3-2027	Respuesta	Ejercicio red team enfocado en cadena de suministro	Tiempo de comunicación al Consejo ≤ 2 h	Equipo de Respuesta
Q4-2027	Inversión	Aprobar presupuesto para SOAR y automatización de respuesta	ROI ≥ 1.5	CFO/CISO
- Visual: Diagrama de Gantt simplificado o línea de tiempo con hitos.
- Comentario: El roadmap es flexible; cada organización puede adaptar los trimestres según su capacidad de gasto y recursos.

Diapositiva 12 – Conclusiones y próximos pasos

- Viñeta 1: Resumen de los hallazgos más críticos (ej. “La detección de TTPs es aceptable, pero la gobernanza y la actualización de parches requieren atención inmediata”).
- Viñeta 2: Propuesta de periodicidad de la encuesta (anual) para monitorizar evolución del IGM y ROI.
- Viñeta 3: Próximos proyectos sugeridos: evaluación de brechas específica, prueba de intrusión enfocada en APT, programa de concienciación continua.
- Viñeta 4: Invitación a participar en foros de intercambio de buenas prácticas entre organizaciones del mismo sector.

Diapositiva 13 – Preguntas y discusión

- Espacio en blanco para comentarios, preguntas del público y anotaciones del presentador.
- Logo y datos de contacto del equipo responsable del estudio.

Notas de diseño

- Tipografía: Sans-serif legible (Calibri, Helvetica, Lato).
- Colores: Azul corporativo para títulos, gris oscuro para texto, verde para indicadores positivos, ámbar para advertencias, rojo para áreas críticas.
- Iconos: usar un set consistente (ej. Material Icons o Fluorescent) para objetivos, preguntas, métricas, etc.
- Pie de página: número de diapositiva y confidencialidad (si corresponde).

**Esta plantilla puede copiarse directamente a PowerPoint, Google Slides o Keynote
sustituyendo los textos de ejemplo por los valores reales obtenidos de las hojas de
cálculo del IGM y el ROI.**